

Guide IA — Audit & Risk Copilot

Plateforme d'audit — Documentation · Généré le 15 mai 2026

1. Principes non négociables

Règle	Détail
Assistive uniquement	L'IA suggère, l'humain décide
Pas d'auto-validation	Aucune approbation workflow automatique
Pas d'auto-exécution	<code>auto_execute_recommendations = false</code>
Traçabilité	Chaque exécution → <code>ai_execution_logs</code> + audit immutable
Sanitization	Réponses filtrées, mention « validation humaine »
Tenant-aware	Contexte limité au pôle de l'utilisateur

2. Architecture LLM

Drivers supportés

Driver	Variable	Usage
<code>stub</code> (défaut)	<code>AI_COPILOT_DRIVER=stub</code>	Développement / hors-ligne
OpenAI	<code>openai</code> + <code>OPENAI_API_KEY</code>	Cloud
Ollama	<code>ollama</code> + <code>OLLAMA_BASE_URL</code>	On-premise
Azure OpenAI	<code>azure_openai</code>	Cloud institutionnel

Fichier config : `config/ai_copilot.php`

Bascule de driver

```
AI_COPILOT_ENABLED=true
AI_COPILOT_DRIVER=openai
OPENAI_API_KEY=sk-...
OPENAI_MODEL=gpt-4o-mini
```

Sans clé API : repli automatique sur **stub**.

3. Accès utilisateur

Page	URL	Qui
Copilote global	/ai	Utilisateurs authentifiés
Copilote mission	/ai/missions/{id}	Accès mission
Assistant	/ai/missions/{id}/assistant	Accès mission
Recommandations	/ai/recommendations	Filtré par visibilité
Recommandations mission	/ai/missions/{id}/recommendations	Accès mission
Analytics	/ai/analytics	Admin menu

Menu latéral : **Copilote IA**

4. Utilisation pas à pas — mission

Scénario A — Question libre

1. Ouvrir `/ai/missions/{mission}`.
2. Saisir la question dans le champ (ex. « Quels contrôles manquent pour l'accès logique ? »).
3. **Obtenir une suggestion IA.**
4. Lire la réponse (badge **IA assistive**).
5. Appliquer manuellement dans le module approprié (risque, constat, etc.).

Scénario B — Synthèse audit

1. Même page → bouton **Synthèse audit**.

2. POST `ai.audit.summary` .
3. Recommandation enregistrée dans `ai_recommendations` .
4. Valider / rejeter en tant qu'auditeur.

Scénario C — Analyse risques

1. Bouton **Analyse risques** → moteur `RiskAiEngineService` .
2. Suggestions : corrélation, scoring, tendances (assistif).
3. Créer les risques officiels **manuellement** dans le registre.

Scénario D — Contrôle interne (ISO, COSO...)

1. Assistant mission → **Contrôles ISO** (ou POST avec `framework=COSO`).
2. Analyse gaps + conformité (assistive).
3. Mapper vers méthodologie `/enterprise/controls` .

Scénario E — Accepter une recommandation

1. `/ai/recommendations` ou recommandations mission.
2. Lire carte recommandation (confiance : low / medium / high).
3. **Marquer revue (humain)** → enregistre `accepted` + `accepted_at` .
4. Ceci **n'exécute pas** l'action — trace la décision humaine.

5. Modules IA spécialisés

Service	Fonction
<code>AuditAiAssistantService</code>	Synthèse mission, incohérences entretien
<code>AuditQuestionGeneratorService</code>	Banque de questions
<code>AuditProgramGeneratorService</code>	Programme d'audit
<code>RiskAiEngineService</code>	Bundle risques
<code>InternalControlAiService</code>	ISO / COSO / COBIT / ITIL / DGCPT
<code>ExecutiveAiAnalyticsService</code>	Narration exécutive, prédictions

6. Gouvernance et sécurité IA

Services

- `AiGovernanceService` — bloque si IA désactivée ou auto-exec tentée
- `AiSafetyService` — détection hallucinations, sanitization
- `AiModerationService` — patterns interdits dans prompts
- `AiPolicyService` — modules autorisés par tenant
- `AiExplainabilityService` — provenance, `source_of_truth = human_auditor`

Modération des prompts

Refus automatique si contenu contenant : contournement, bypass, auto approve, etc.

7. Observabilité IA (admins)

URL : `/observability/enterprise/ai`

Métrique	Description
Exécutions	Total appels LLM
Échecs	Statut <code>failed</code>
Latence moyenne	ms
Conversations	Volume
Pending validation	Recommandations non traitées

Analytics détaillés : `/ai/analytics` (répartition par driver).

8. Données persistées

Table	Rôle
ai_conversations	Fil de contexte
ai_recommendations	Suggestions
ai_analysis_snapshots	Snapshots input/output hashés
ai_execution_logs	Latence, driver, statut
ai_prompt_templates	Prompts par département / contexte

9. Intégration workflow

Étapes dédiées :

- swot_analysis / swot_validation
- raci_assignment / raci_validation

L'IA peut suggérer du contenu ; la **validation d'étape** reste une action humaine dans le runtime (approve / reject).

10. Bonnes pratiques

1. Toujours indiquer en comité de mission que la sortie IA est **provisoire**.
 2. Ne pas copier-coller une suggestion comme constat officiel sans revue.
 3. Pour données sensibles : privilégier driver **Ollama** on-premise.
 4. Réviser mensuellement les logs IA (coûts, échecs).
 5. Former les équipes au badge **Non contraignant**.
-

11. Dépannage

Problème	Solution
Réponse générique stub	Configurer driver LLM réel
403 mission	Vérifier tenant / équipe mission
IA désactivée	<code>AI_COPILOT_ENABLED=true</code>
Pas de recommandation en base	Vérifier migrations <code>ai_*</code>

12. Voir aussi

- [Guide utilisateur](#)
 - [Manuel sécurité](#)
 - [Guide exploitation](#)
-